

Network Security 2025

COMSM0123_2025_TB-1

Secure-by-Design Network Implementation in GNS3

Technical Report

Student Name: Yi Li
Student No.: 2829967
Module: Network Security 2025
Submission: 19 December 2025

This report documents the implemented topology, security controls, and validation tests.

Contents

1	Executive Summary	4
2	Network Architecture Design	4
2.1	Design Rationale	4
2.2	Network Topology	6
2.2.1	Core Security Components	7
2.2.2	IP Addressing and Scalability	7
2.2.3	Mandatory Infrastructure and Testing	7
2.3	IP Address Schemes	8
3	Security Control Implementation	9
3.1	Access Control Mechanisms	9
3.1.1	Policy Objectives	9
3.1.2	Firewall Configuration Evidence	10
3.2	Network Segmentation	15
3.2.1	Segmentation Objectives	15
3.2.2	Zone & Inter-Zone Design	16
3.3	Additional Security Hardening	17
3.3.1	Secure Management Baseline	17
3.3.2	Service Minimisation and Attack Surface Reduction	18
3.3.3	Layer-2 Security Considerations (Environment Constraints)	18
4	Security Testing and Validation	19
4.1	Testing Environment	19
4.2	Validation Methodology	20
4.3	Test Cases and Results	20
5	Critical Evaluation (Strengths & Limitations)	21
5.1	Limitations	22
5.2	Summary	23
6	Conclusion	23
A	Appendix A: Screenshots and Config Snippets	26

List of Figures

1	TechCorp Ltd Secure Network Topology using GNS3	6
2	Integration of GNS3 with VMware via Custom VMnet Adapters	8
3	Aliases Configuration	10
4	Firewall Configuration for the Management Zone (MGMT)	11
5	Access to WebGUI	11
6	Corporate (LAN) Firewall Policy Evidence: These rules enforce management-plane isolation by blocking the LAN from accessing the MGMT subnet and pfSense management interfaces (SSH/HTTPS).	12
7	Guest WiFi Firewall Policy Evidence: The kill-switch blocks access to all internal RFC1918 networks (Internal_nets), while only permitting essential outbound services for Internet browsing.	13
8	DMZ Firewall Policy Evidence: DMZ is prevented from initiating connections to internal Corporate and Management networks, limiting lateral movement from public-facing services.	14
9	Perimeter exposure control: only the DMZ web service is published to the Internet via WAN port forwarding and a linked WAN rule.	15
10	User Password Manager.	26
11	T1: WAN exposure validation via Nmap (only TCP/80 reachable).	26
12	T2: Guest Internet reachability (Guest1 → 1.1.1.1 succeeds).	27
13	T3: Guest isolation (Guest1 → internal addresses blocked).	27
14	T4: LAN to MGMT blocked (PC-SALES → MGMT timeout).	28
15	T5: MGMT reachability to internal network (SRV-ADM can reach internal gateway).	28
16	T6: DMZ containment (SRV-WEB → LAN host blocked).	29

List of Tables

1	IP Addressing Scheme and Allocation Plan	8
2	Segmentation Matrix (Initiated Traffic): Allowed/Denied Inter-Zone	17
3	Additional Security Hardening Checklist: baseline controls applied and implementation evidence.	19
4	Security validation summary (initiated traffic).	20

1 Executive Summary

This project designed and implemented a secure-by-design enterprise network for TechCorp using GNS3 and PfSense. TechCorp, a medium-sized company, requires a redesigned network infrastructure to address recent security incidents.

To enhance network security, the project uses the pfSense firewall as the boundary and access control centre, dividing the network into five secure zones: External/WAN (external network), Corporate (internal network of the company), DMZ (external service area), Guest (guest network), and MGMT (management network). Each area adopts an independent network segment and gateway configuration, which achieves isolation structurally and reduces the risk of mutual influence among different regions. The internal network adopts a hierarchical topology of core-distribution-access, which is convenient for expansion and management. The access policy restricts the external network to only allow access to the DMZ's external service ports. Guests are only allowed to access the Internet and are prohibited from accessing the company's internal network and management network. MGMT is only used for the management access of devices and servers.

The following sessions of this report are organised as follows: Section 2 details the secure network architecture design, including the design rationale, the GNS3 network topology, and the comprehensive IP addressing scheme, which forms the foundation for the implementation of security controls in Section 3. Section 3 describes the implementation of security controls, covering access control mechanisms, network segmentation strategies, and additional system hardening. The security testing and validation process, conducted via a Kali Linux VM bridge, is presented in Section 4 based on the rules introduced in Section 2. Section 5 provides a critical evaluation of the strengths and limitations of the design. Finally, Section 6 concludes the report with a summary of the project's findings and recommendations.

2 Network Architecture Design

2.1 Design Rationale

TechCorp's recent security issues demonstrated the need to stop using a flat network and establishing more explicit trust boundaries. In this setup, pfSense serves as the gateway and the point at which all inter-zone traffic is inspected and controlled. The network is divided into five zones — External/WAN, Corporate, DMZ, Guest and MGMT — so that public-facing services reside in the DMZ and are never afforded the same trust level as internal users or management systems. This narrows the attack surface and makes lateral movement between zones more challenging [11, 12]. Internally, the core sizes to the distribution then access, hierarchical Core–Distribution–Access topology keeps design modular and scalable, it separates aggregation from edge endpoints that provision and terminate users [6]. The design, rather than just being depen-

dent upon screenshots of the configurations, is verified against a series of quantifiable validation tests. These tests associate every security objective with a testable effect under examination.

1. Logical Architecture Mapping. The design ensures clear separation of security zones (External/Kali, DMZ, and internal department VLANs) and a connectivity matrix is provided. This matrix states explicitly paths that are allowed and those that are forbidden, for example:

- **Kali → DMZ: *Allowed***

The DMZ is intended to contain public-facing services like Web and DNS servers. The External/Kali zone is allowed access to these services to provide access to legitimate external users. This is much like the real world where a company's public servers need to be accessible from the internet to conduct business.

- **Kali → Internal VLANs: *Denied***

Direct access from the external WAN (Kali) to the internal departments (Sales/Dev) is prohibited for the protection of sensitive company information and internal network. This design decision essentially "closed off" the company's internal core assets from the outdoors, disallowing any external access.

- **Guest → Internet: *Allowed***

The Guest WiFi is for transient guests with basic internet needs. The business need is satisfied by providing guest access to the Internet (and not the Corporate network) by allowing Internet access and denying access to internal resources.

2. Hierarchical Network Structure. The implementation follows an explicit Core– Distribution –Access model, supported by a structured VLAN/subnet plan (including IDs, purpose, and IP subnets).

3. Testable Implementation Metrics. The security posture is assessed via five key metrics:

- (i) Connectivity (ICMP Validation):** Using `ping` or `traceroute` from end-devices (e.g., PC-SALES, Guest-1) to verify successful reachability between authorized zones. This confirms that the basic routing and gateway configurations on pfSense are functioning correctly.
- (ii) Access-Control (Stateful Inspection):** Validating pfSense firewall rules by attempting to initiate connections across zone boundaries. This ensures that only traffic matching specific security policies is allowed, while all other stateful connections are dropped.
- (iii) Segmentation/Isolation (Boundary Testing):** Performing `ping` tests from the *Guest* and *External* zones toward the *Corporate* and *MGMT* networks. The metric is a 100% packet loss (Request Timed Out), proving that the isolation between sensitive departments and untrusted networks is effectively enforced.

- (iv) **Attack-Surface Metrics (Nmap Scanning):** Conducting nmap scans from the Kali Linux VM to the DMZ and internal hosts. This verifies that: Only necessary service ports (e.g., HTTP 80, DNS 53) are open and non-essential ports are filtered to minimize vulnerability windows and prevent potential exploitation of unused services.
- (v) **Hardening Metrics (Service Security):** Verifying the "Secure by Default" posture by checking if insecure protocols (e.g., Telnet, HTTP for management) are disabled. We confirm that management access to switches and pfSense is restricted to the *MGMT* zone via encrypted *SSH* only.

The detailed test results for these metrics, which validate the integrity of the proposed design rationale, will be discussed in Section 4: Security Testing and Validation.

2.2 Network Topology

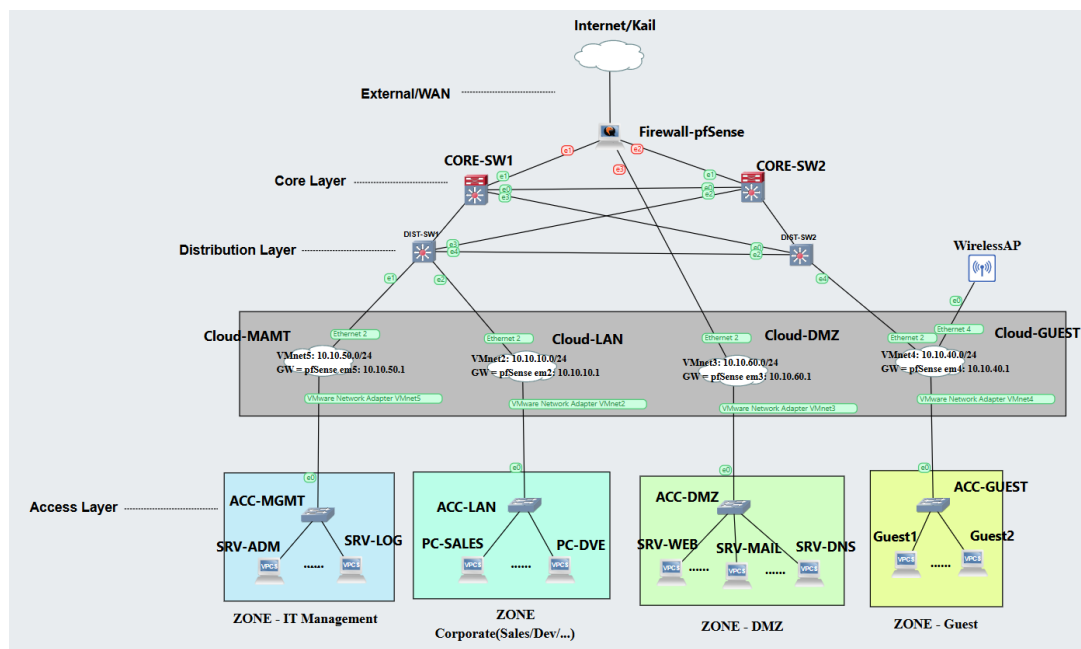


Figure 1: TechCorp Ltd Secure Network Topology using GNS3

Note: Captured from GNS3 Web interface at <http://localhost:3080>

As illustrated in Figure 1, the topology fulfills TechCorp's security requirements through a modular and scalable design. The architecture centralizes security policies within a pfSense gateway, which manages five isolated zones. A key implementation detail is the use of Cloud nodes (highlighted in the grey shaded area). While these nodes are usually omitted in physical diagrams, they serve as essential Virtual Network Bridges in this environment, mapping GNS3 interfaces to specific VMware VMnet adapters to allow the external pfSense VM to act as the central gateway for all simulated segments. Each requirement in task1.1 will be explained in the following session.

2.2.1 Core Security Components

The following components establish the "Secure-by-Design" foundation for TechCorp:

- **Hierarchical Model:** By using CORE-SW1/2 for backbone traffic and DIST-SW1/2 for aggregation, the design ensures no single point of failure. And this allows security policies to be enforced at the Distribution layer before traffic reaches the core assets.
- **Departmental Segmentation:** The Corporate zone is segmented into Sales, Development, and Management subnets. This design limits the scope of potential damage. For instance, a compromise within the sales department is isolated, which ensures that it does not automatically grant access to the Development or Management zones.
- **Isolated DMZ:** A dedicated subnet (10.10.60.0/24) hosts the Web, DNS, and Email servers. It provides a buffer zone that prevents direct external access to the internal network; if a DMZ service is breached, the firewall still protects the Corporate and MGMT zones [4].
- **Unified Perimeter Defense:** The pfSense firewall interface (em0/em1) manages all inter-zone traffic. By forcing all traffic (e.g., Guest to Corporate) through a single enforcement point, the network ensures 100% stateful inspection and granular ACL filtering.

2.2.2 IP Addressing and Scalability

The addressing plan utilizes RFC 1918 standards to enhance internal network obfuscation and management [1]:

- **Subnetting Strategy:** Each security zone and department is assigned a unique 10.10.x.0/24 subnet. This facilitates clear firewall rule creation based on network objects, reducing the risk of configuration errors.
- **Future Growth Reservations:** By utilizing /24 masks and reserving specific IP ranges, the design accommodates future expansion without re-addressing. This ensures security policies remain consistent and manageable as the number of devices grows.

2.2.3 Mandatory Infrastructure and Testing

The topology incorporates all required devices to support a resilient security posture:

- **Security Gateway & Multilayer Switches:** Devices like pfSense and CORE-SW1 provide the necessary routing and security features. These devices support critical hardening measures like disabling Telnet and enforcing SSH.
- **Kali Linux Integration via Cloud:** The WAN Cloud node bridges the simulation to the external Kali Linux VM. This allows the network's resilience to be objectively validated through external vulnerability scanning and penetration testing, ensuring the implementation meets real-world security standards.

2.3 IP Address Schemes

The network addressing plan utilizes RFC 1918 private address ranges to establish a secure and manageable internal environment. Each security zone is allocated a dedicated /24 subnet (255.255.255.0) to facilitate granular segmentation and simplify the implementation of firewall policies based on network boundaries.

Table 1: IP Addressing Scheme and Allocation Plan

Security Zone	Subnet Range	Gateway (pfSense)	Key Host Allocation / Purpose
External/WAN	192.168.73.0/24	192.168.73.131	Kali Linux VM (External Testing Node)
Corporate (LAN)	10.10.10.0/24	10.10.10.1	PC-SALES, PC-DVE (Static: .50–.100)
DMZ	10.10.60.0/24	10.10.60.1	Web (.10), Mail (.11), DNS (.12) Servers
Guest WiFi	10.10.40.0/24	10.10.40.1	Guest1, Guest2, Wireless AP (.20)
Management	10.10.50.0/24	10.10.50.1	SRV-ADM (.10), SRV-LOG (.11)

The addressing strategy ensures that pfSense serves as the default gateway (standardized at the .1 address) for all internal interfaces, centralizing cross-zone routing and stateful inspection. To support future scalability, the project reserves the high-order address range (.101–.254) in each subnet for departmental expansion, ensuring the network can accommodate growth without requiring a re-addressing of the core infrastructure.

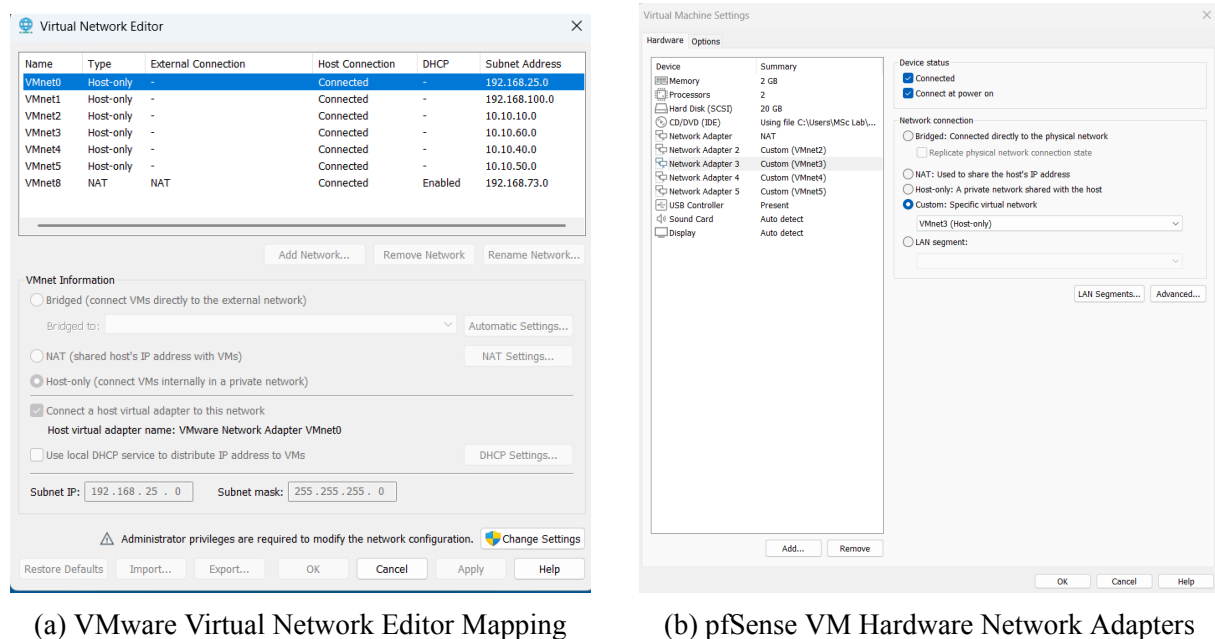


Figure 2: Integration of GNS3 with VMware via Custom VMnet Adapters

At the implementation level, these logical zones are mapped to physical-like isolation using

VMware Host-only networks. As shown in Figure 2, the GNS3 Cloud nodes bridge the simulated environment to the pfSense VM through dedicated virtual adapters:

- **VMnet2 (10.10.10.0):** Corporate / Internal LAN segment.
- **VMnet3 (10.10.60.0):** DMZ hosting public-facing services.
- **VMnet4 (10.10.40.0):** Isolated Guest network.
- **VMnet5 (10.10.50.0):** Restricted Management (MGMT) zone.
- **VMnet8 (192.168.73.0):** WAN/NAT interface for external access and Kali connectivity.

3 Security Control Implementation

This section details the practical implementation of the security controls designed in Section 2. The configuration follows a "Secure-by-Default" posture, prioritized by establishing a dedicated management path before enforcing restrictive policies on production traffic. The configuration evidence will be shown in this section and verification evidence will be shown in the next section.

3.1 Access Control Mechanisms

The primary defense mechanism is the pfSense stateful firewall, which mediates all inter-zone communication [?]. The implementation follows the Principle of Least Privilege, ensuring that only necessary business traffic is permitted [5].

3.1.1 Policy Objectives

The access control strategy is governed by four core security requirements:

- **Restricted Management:** Only the MGMT zone is authorized to access the pfSense web GUI and infrastructure management interfaces.
- **Guest Isolation:** The Guest zone is permitted outbound Internet access but is strictly prohibited from reaching any internal corporate segments.
- **Perimeter Protection:** External WAN traffic is restricted to public-facing DMZ services only; direct access to Corporate or MGMT zones is denied.
- **Corporate Least Privilege:** Internal departments (Sales/Dev) can access DMZ services and the Internet but are blocked from the Management network to prevent internal reconnaissance.

3.1.2 Firewall Configuration Evidence

Network Aliases. To improve rule readability and reduce configuration errors, pfSense *Aliases* were used as reusable objects for common network and service definitions. In particular, internal security zones are grouped into a single logical set (e.g., INTERNAL_NETS) and private RFC1918 address space is represented as an object (e.g., RFC1918). These objects are referenced by interface rules to express policy intent (e.g., “block Guest to internal networks”) without repeatedly listing individual subnets, which enhances maintainability as the topology grows. Figure 3 shows the specification of Aliases

Firewall / Aliases / Edit

Properties

Name Internal_nets
The name of the alias may only consist of the characters "a-z, A-Z, 0-9 and _".

Description
A description may be entered here for administrative reference (not parsed).

Type Network(s)

Network(s)

Hint Networks are specified in CIDR format. Select the CIDR mask that pertains to each entry. /32 specifies a single IPv4 host, /128 specifies a single IPv6 host, /24 specifies 255.255.255.0, /64 specifies a normal IPv6 network, etc. Hostnames (FQDNs) may also be specified, using a /32 mask for IPv4 or /128 for IPv6. An IP range such as 192.168.1.1-192.168.1.254 may also be entered and a list of CIDR networks will be derived to fill the range.

Network or FQDN				
10.10.10.0	/	24	Entry added Fri, 19 Dec 2025 15:57:20 +0000	Delete
10.10.40.0	/	24	Entry added Fri, 19 Dec 2025 15:57:20 +0000	Delete
10.10.50.0	/	24	Entry added Fri, 19 Dec 2025 15:57:20 +0000	Delete
10.10.60.0	/	24	Entry added Fri, 19 Dec 2025 15:57:20 +0000	Delete

Save Export to file Add Network

Figure 3: Aliases Configuration

Management Zone (MGMT) Rules. A dedicated Management zone is used to reduce the attack surface of the firewall administration plane. On the MGMT interface, explicit PASS rules were created to permit only administrative services destined for the firewall itself (*This Firewall/self*). Specifically, HTTPS (TCP/443) is allowed for WebGUI administration and SSH (TCP/22) is allowed for remote shell access from the MGMT subnet only. All other unsolicited traffic to the firewall on this interface is implicitly denied by pfSense’s default policy, enforcing least-privilege access to management services.

Figure 4 shows that administrative access is constrained to the MGMT subnet and restricted to ports 443 and 22, providing a clear separation between operational traffic and management access.

Firewall / Rules / Edit

Edit Firewall Rule

Action Pass

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface MGMT
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol TCP
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match MGMT subnets Source Address / |

[Display Advanced](#)
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match This Firewall (self) Destination Address / |

Destination Port Range HTTPS (443) Custom To Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log ☐ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description Allow MGMT to pfSense WebGUI (HTTPS)
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset label and displayed in the firewall log.

Advanced Options [Display Advanced](#)

Rule Information

Tracking ID	1766150992
Created	12/19/25 13:29:52 by admin@10.10.10.254 (Local Database)
Updated	12/19/25 13:29:52 by admin@10.10.10.254 (Local Database)

(a) Allow MGMT to pfSense WebGUI (HTTPS)

Firewall / Rules / Edit

Edit Firewall Rule

Action Pass

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface MGMT
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol TCP
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match MGMT subnets Source Address / |

[Display Advanced](#)
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match This Firewall (self) Destination Address / |

Destination Port Range SSH (22) Custom To Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log ☐ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description Allow MGMT to pfSense SSH
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset label and displayed in the firewall log.

Advanced Options [Display Advanced](#)

Rule Information

Tracking ID	1766151247
Created	12/19/25 13:34:07 by admin@10.10.10.254 (Local Database)
Updated	12/19/25 13:34:07 by admin@10.10.10.254 (Local Database)

(b) Allow MGMT to pfSense SSH

Figure 4: Firewall Configuration for the Management Zone (MGMT)

And Figure 5 verifies that MGMT can successfully open the WebGUI.

pfSense
Community Edition

System - Interfaces - Firewall - Services - VPN - Status - Diagnostics - Help

Status / Dashboard

System Information

Name	pfSense home arpa
User	admin@10.10.10.254 (Local Database)
System	VMware Virtual Machine Netgate Device ID: 7d547ed95846423e7f4
BIOS	Vendor: Phoenix Technologies LTD Version: 6.00 Release Date: Thu 12 2020 Boot Method: BIOS
Version	2.8.1-RELEASE (amd64) Built on Mon Dec 15 17:31:00 UTC 2025 FreeBSD: 15.0-CURRENT The system is on the latest version. Version information updated at Fri Dec 19 13:41:05 UTC 2025
CPU Type	Intel(R) Core(TM) Ultra 7 165H 2 CPUs x 2 package(s) x 1 core(s) AES-NI CPU Crypto: Yes (inactive) QAT Crypto: No
Hardware crypto	Inactive
Kernel PTI	Disabled
MDS Mitigation	Inactive
Uptime	02 Hours 29 Minutes 21 Seconds
Current date/time	Fri Dec 19 13:56:49 UTC 2025
DNS server(s)	127.0.0.1 192.168.73.2
Last config change	Fri Dec 19 13:55:06 UTC 2025
State table size	0% (22/19900) Show status
MBUF Usage	1% (7112/1000000)
Load average	0.60, 0.40, 0.29
CPU usage	2%
Memory usage	15% of 1591 MB
SWAP usage	0% of 1024 MB

Disks

Mount	Used	Size	Usage
/	898M	16G	6% of 16G (pts)

Netgate Services And Support

Contract type: Community Support
Community Support Only

NETGATE AND pfSense COMMUNITY SUPPORT RESOURCES

If you purchased your pfSense gateway firewall appliance from Netgate and elected **Community Support** at the point of sale or installed pfSense on your own hardware, you have access to various community support resources. This includes the **NETGATE RESOURCE LIBRARY**.

You also may upgrade to a Netgate Global Technical Assistance Center (TAC) Support subscription. We're always on Our team is staffed 24x7x365 and committed to delivering enterprise-class, worldwide support at a price point that is more than competitive when compared to others in our space.

- Upgrade Your Support
- Community Support Resources
- Netgate Global Support FAQ
- Official pfSense Training by Netgate
- Netgate Professional Services
- Visit Netgate.com

If you decide to purchase a Netgate Global TAC Support subscription, you **MUST** have your Netgate Device ID (NDI) from your firewall in order to validate support for this unit. Write down your NDI and store it in a safe place. You can purchase TAC supports here.

Interfaces

Interface	IP Address	Subnet
WAN	192.168.73.131	100baseT <full-duplex>
LAN	10.10.10.1	100baseT <full-duplex>
DMZ	10.10.60.1	100baseT <full-duplex>
GUEST	10.10.40.1	100baseT <full-duplex>
MGMT	10.10.50.1	100baseT <full-duplex>

Figure 5: Access to WebGUI

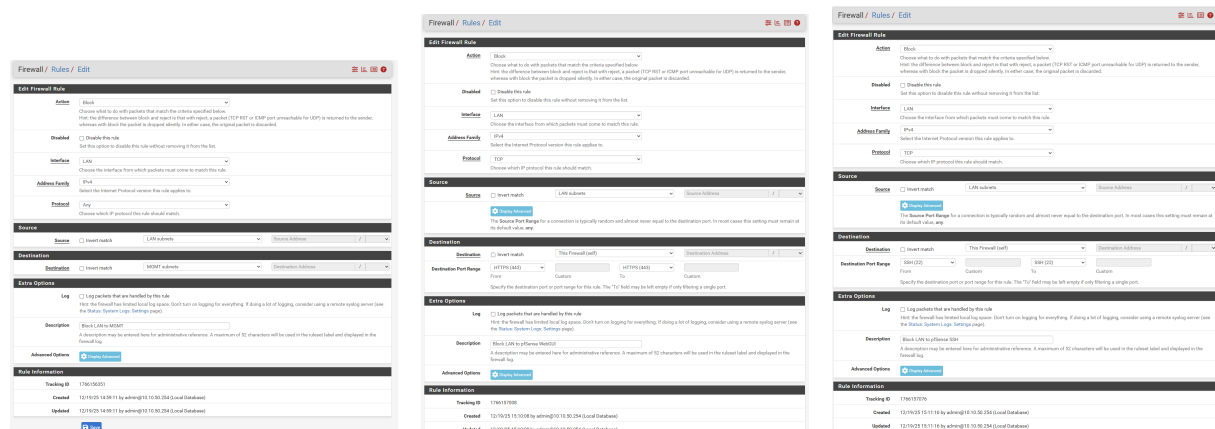
Corporate (LAN) Rules. The Corporate LAN follows a least-privilege approach to reduce lateral movement and internal reconnaissance risks. As shown in Figure 6, explicit BLOCK rules are placed above the default allow LAN to any policy to (i) deny administrative access from the LAN to the firewall itself (SSH on TCP/22 and WebGUI on TCP/443), and (ii) deny any

LAN-initiated traffic destined to the Management subnet (MGMT subnets). This ensures that day-to-day user devices in the Corporate zone cannot reach the management plane or management hosts, while normal outbound connectivity and business-required access remain available via the default LAN allow rule.

Note: pfSense includes an anti-lockout safeguard rule on the LAN interface to prevent accidental loss of WebGUI access. Therefore, management-plane isolation is primarily evidenced by the MGMT-only administration policy and by blocking LAN access to the MGMT subnet, with validation results presented in the testing section.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/1.56 MiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
☐	0/0 B	IPv4 TCP	LAN subnets	*	This Firewall (self)	22 (SSH)	*	none		Block LAN to pfSense SSH	
☐	0/0 B	IPv4 TCP	LAN subnets	*	This Firewall (self)	443 (HTTPS)	*	none		Block LAN to pfSense WebGUI	
☐	0/0 B	IPv4 *	LAN subnets	*	MGMT subnets	*	*	none		Block LAN to MGMT	
☐	0/0 B	IPv4 ICMP	LAN subnets	*	DMZ address	*	*	none		LAN ping DMZ gateway	
☐	0/4 KiB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

(a) LAN Rules Overview: Demonstrating Rule Order and Policy Logic



(b) Block LAN to MGMT

(c) Block LAN to WebGUI

(d) Block LAN to SSH

Figure 6: Corporate (LAN) Firewall Policy Evidence: These rules enforce management-plane isolation by blocking the LAN from accessing the MGMT subnet and pfSense management interfaces (SSH/HTTPS).

Guest & WiFi Rules. The Guest zone is designed for untrusted endpoints and therefore enforces strict isolation from all internal assets. As shown in Figure 7, a kill-switch policy is implemented by placing an explicit BLOCK rule at the top of the GUEST ruleset to deny any Guest-initiated traffic destined for Internal_nets (an alias grouping all internal RFC1918 subnets, including Corporate, DMZ, and MGMT). This prevents lateral movement from the Guest

network into enterprise segments by default.

To preserve basic usability for visitors, only essential outbound services are permitted: DNS (TCP/UDP 53) for name resolution and web traffic (HTTP/80 and HTTPS/443) for Internet access. All other destinations and ports remain implicitly denied by policy. Validation evidence (e.g., Guest→Internet success and Guest→Internal_nets failure using ping/traceroute/nmap) is presented in the testing section.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓	0/0 B	IPv4 TCP	GUEST subnets	*	*	443 (HTTPS)	*	none	Allow Guest HTTP	
☐	✓	0/0 B	IPv4 TCP	GUEST subnets	*	*	80 (HTTP)	*	none	Allow Guest HTTP	
☐	✓	0/0 B	IPv4 TCP/UDP	GUEST subnets	*	*	53 (DNS)	*	none	Allow Guest DNS	
☐	✗	0/0 B	IPv4 *	GUEST subnets	*	Internal_nets	*	*	none	Guest kill-switch:block to internal_nets	
☐	✓	0/0 B	IPv4 ICMP any	GUEST subnets	*	This Firewall (self)	*	*	none		

(a) GUEST Rules Overview: Demonstrating Rule Order and Policy Logic

(b) Kill-switch: Block Guest to Internal_nets

(c) Allow Guest HTTP (80)

(d) Allow Guest HTTPS (443)

Figure 7: Guest WiFi Firewall Policy Evidence: The kill-switch blocks access to all internal RFC1918 networks (Internal_nets), while only permitting essential outbound services for Internet browsing.

DMZ Rules. The DMZ is treated as a semi-trusted zone that hosts public-facing services (e.g., Web/DNS/Mail). To prevent pivoting from exposed servers into internal networks, restrictive outbound controls are enforced on the DMZ interface. As shown in Figure 8, explicit BLOCK rules are placed above other policies to deny any DMZ-initiated traffic destined for internal segments, including (i) the Corporate network (LAN subnets) and (ii) the management plane (MGMT subnets). This design ensures that even if a DMZ host is compromised, lateral movement into Corporate or Management networks is structurally constrained.

For operational visibility and basic troubleshooting, limited ICMP is permitted between the DMZ subnet and the firewall (gateway). Any additional outbound requirements from DMZ to the Internet (e.g., DNS and HTTP/HTTPS for updates) are handled under a minimal-necessary principle and validated in the testing section.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✗ 0/0 B	IPv4 TCP	DMZ subnets	*	LAN subnets	*	*	none		Block DMZ to LAN	  
☐	✗ 0/0 B	IPv4 TCP	DMZ subnets	*	MGMT subnets	*	*	none		Block DMZ to MGMT	  
☐	✓ 0/0 B	IPv4 ICMP any	DMZ subnets	*	DMZ address	*	*	none			   
☐	✓ 0/0 B	IPv4 ICMP any	DMZ subnets	*	This Firewall (self)	*	*	none		Allow DMZ ping firewall	   

 Add
  Add
  Delete
  Toggle
  Copy
  Save
  Separator

(a) DMZ Rules Overview: rule order and high-level policy

Firewall / Rules / Edit

Edit Firewall Rule

Action: Block
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled: ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface: DMZ
Choose the interface from which packets must come to match this rule.

Address Family: IPv4
Select the Internet Protocol version this rule applies to.

Protocol: TCP
Choose which IP protocol this rule should match.

Source: ☐ Invert match DMZ subnets Source Address: /

Destination: ☐ Invert match LAN subnets Destination Address: /

Destination Port Range: From any To any Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options:

Log: ☐ Log packets that are handled by this rule
Hint: the firewall has limited log log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description: Block DMZ to LAN
A description may be entered here for administrative reference. A maximum of 512 characters will be used in the ruleset label and displayed in the firewall log.

Advanced Options: 

Rule Information:

Tracking ID	1766164265
Created	12/19/25 17:11:05 by admin@10.10.50.254 (Local Database)
Updated	12/19/25 17:11:05 by admin@10.10.50.254 (Local Database)

(b) Block DMZ to Corporate (LAN subnets)

Firewall / Rules / Edit

Edit Firewall Rule

Action: Block
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled: ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface: DMZ
Choose the interface from which packets must come to match this rule.

Address Family: IPv4
Select the Internet Protocol version this rule applies to.

Protocol: TCP
Choose which IP protocol this rule should match.

Source: ☐ Invert match DMZ subnets Source Address: /

Destination: ☐ Invert match MGMT subnets Destination Address: /

Destination Port Range: From any To any Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options:

Log: ☐ Log packets that are handled by this rule
Hint: the firewall has limited log log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description: Block DMZ to MGMT
A description may be entered here for administrative reference. A maximum of 512 characters will be used in the ruleset label and displayed in the firewall log.

Advanced Options: 

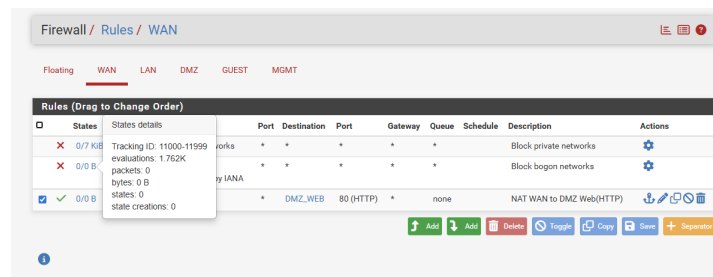
Rule Information:

Tracking ID	1766164215
Created	12/19/25 17:10:15 by admin@10.10.50.254 (Local Database)
Updated	12/19/25 17:10:15 by admin@10.10.50.254 (Local Database)

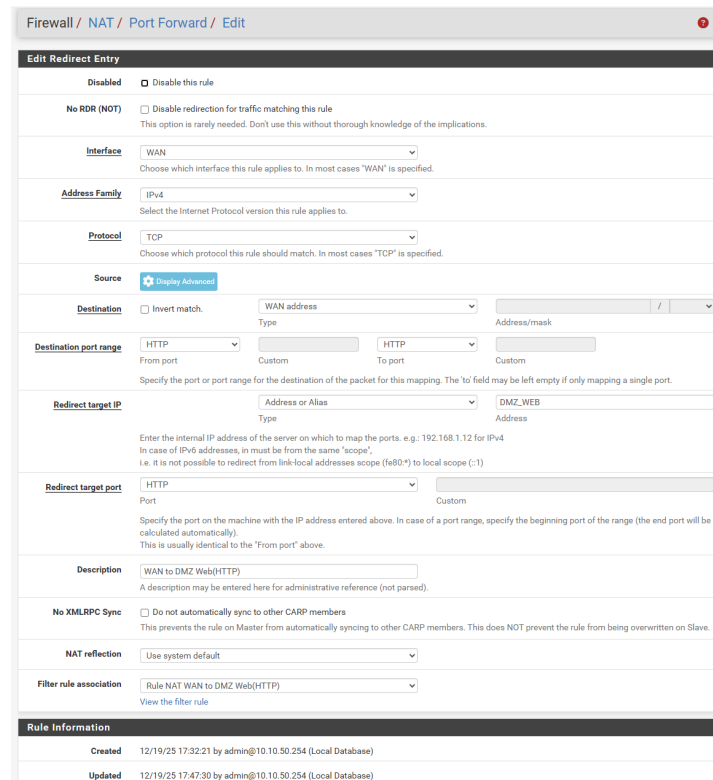
(c) Block DMZ to Management (MGMT subnets)

Figure 8: DMZ Firewall Policy Evidence: DMZ is prevented from initiating connections to internal Corporate and Management networks, limiting lateral movement from public-facing services.

External (WAN) Rules & NAT. To satisfy the requirement of exposing only public-facing services while shielding internal segments, a port forwarding rule was configured on the WAN interface to publish the DMZ web server. Specifically, inbound TCP/80 traffic destined to the pfSense WAN address is redirected to the DMZ web host (DMZ_WEB, 10.10.60.10:80). As evidenced in Figure 9b, pfSense performs destination NAT to the DMZ host and automatically installs a linked WAN firewall rule (Figure 9a) that permits only this service, while all other unsolicited WAN-to-internal traffic remains blocked by default.



(a) WAN firewall rule generated for the DMZ web service



(b) Port forward: WAN TCP/80 → DMZ_WEB (10.10.60.10:80)

Figure 9: Perimeter exposure control: only the DMZ web service is published to the Internet via WAN port forwarding and a linked WAN rule.

3.2 Network Segmentation

Network segmentation is implemented to reduce lateral movement and to ensure that each business/security zone has a clearly defined trust level. The project adopts a zone-based design centred on pfSense, where each zone is bound to an independent Layer-3 interface and subnet (WAN, Corporate/LAN, DMZ, GUEST, MGMT). All inter-zone traffic is therefore forced to traverse the pfSense stateful firewall, enabling consistent policy enforcement and auditability.

3.2.1 Segmentation Objectives

The segmentation strategy follows three objectives:

- **Isolation by default:** Zones are separated at Layer-3 and cannot communicate unless an explicit policy allows it.
- **DMZ as a controlled boundary:** Public-facing services are hosted in the DMZ so that Internet exposure does not extend into internal corporate or management networks.
- **Separation of guest area and management area:** The MGMT subnet is treated as a dedicated management plane for administrative access only.

3.2.2 Zone & Inter-Zone Design

Each zone is assigned a dedicated RFC1918 subnet and gateway on pfSense, providing clear trust boundaries and simplifying policy reasoning. Corporate users operate within the LAN zone; Internet-facing servers (e.g., Web/DNS/Mail) reside in the DMZ; guests are placed in an isolated GUEST zone; and administrative hosts/tools are placed in the MGMT zone.

Inter-zone routing is not performed by access switches; instead, pfSense provides the default gateway for each subnet. This ensures that all cross-zone paths are subject to firewall rule evaluation (stateful inspection), rather than permitting uncontrolled east–west traffic. As a result, segmentation is both structural (separate subnets) and policy-driven (explicit allow/deny rules).

Segmentation and implementation. The desired segmentation boundaries are guaranteed by the interface’s own rules and can be seen in the configurations in Section 3.1:

- **Guest isolation:** a kill-switch blocks GUEST→Internal_nets, while permitting only essential Internet access (HTTP/HTTPS) (Figure 7).
- **Management plane isolation:** LAN is blocked from reaching MGMT subnets to reduce internal reconnaissance risk (Figure 6); Administrative access to pfSense is constrained to MGMT only (Figure 4).
- **DMZ containment:** DMZ hosts are prevented from initiating connections into Corporate/LAN and MGMT to reduce the possibility of any exposed service (Figure 8).
- **Perimeter segmentation:** Inbound WAN access is constrained to DMZ public services only via controlled NAT and a linked WAN rule (Figure 9).

Table 2 summarises the initiated-flow connectivity policy between security zones. Each unit indicates whether the source area can initiate traffic to the destination area. PfSense is a stateful firewall: once a permitted connection is established, return traffic is automatically allowed. Therefore, the matrix focuses on who is allowed to initiate communications across zones. “N/A” indicates same-zone traffic that typically does not traverse the firewall, and “LIMITED” indicates narrowly scoped access (e.g., ICMP to the gateway for basic reachability checks). Also,

guest outbound Internet access (DNS/HTTP/HTTPS) is permitted; the matrix focuses on inter-zone communications within the enterprise zones.

Source \ Destination	DMZ	Corporate (LAN)	Guest	MGMT	pfSense (Self/Mgmt)
External/WAN	ALLOW	DENY	DENY	DENY	DENY
Corporate (LAN)	ALLOW	N/A	DENY	DENY	LIMITED
Guest	DENY	DENY	N/A	DENY	DENY
DMZ	N/A	DENY	DENY	DENY	LIMITED
MGMT	ALLOW	ALLOW	DENY	N/A	ALLOW

Table 2: Segmentation Matrix (Initiated Traffic): Allowed/Denied Inter-Zone

The matrix is realised by the interface-specific pfSense policies evidenced in Section 3.1: WAN exposure is restricted to DMZ services only (Figure 9); the Guest kill-switch blocks access to `Internal_nets` (Figure 7); LAN is blocked from reaching MGMT and pfSense management ports (Figure 6); and DMZ is contained by blocking DMZ-initiated traffic to LAN and MGMT (Figure 8). MGMT remains the only authorised zone for firewall administration (Figure 4).

3.3 Additional Security Hardening

Beyond segmentation and access-control policies, additional hardening measures were applied to reduce the attack surface and improve baseline security posture. The hardening controls follow common secure-by-default practices, including stronger authentication, secure management protocols, and minimising exposed services.

3.3.1 Secure Management Baseline

Strong credentials and removal of defaults. All administrative accounts were secured by changing default credentials and enforcing strong passwords (Figure 10). This reduces the risk of trivial compromise through credential reuse or vendor-default passwords.

Disable Telnet; SSH-only administration. Insecure plaintext management protocols (e.g., Telnet) were not used. Remote administration is performed using SSH only (TCP/22), and access to management services is constrained to the MGMT zone as described in Section 3.1 (Figure 4). This ensures confidentiality of administrative sessions and reduces exposure of the management plane.

⁰pfSense includes an anti-lockout safeguard on the LAN interface; management-plane isolation is primarily enforced by MGMT-only administration and LAN→MGMT blocking (Section 3.1).

Restrict management interfaces to the MGMT zone. The pfSense WebGUI (HTTPS/443) and SSH (22) are intended to be reachable only from the MGMT subnet. Access attempts from non-management zones are blocked by policy (Figure 6), enforcing separation between operational traffic and the management plane.

3.3.2 Service Minimisation and Attack Surface Reduction

Expose only required WAN services. The perimeter configuration follows an allow-list approach: only the DMZ public web service is published to the Internet via port forwarding (WAN TCP/80 to DMZ_WEB = 10.10.60.10) with a linked WAN rule (Figure 9). All other unsolicited inbound connections remain blocked by default, limiting externally visible services and reducing the attack surface.

Disable unnecessary services. Services that are not required for the project scenario are kept disabled to reduce exploitable surface area. Where a service is required (e.g., WebGUI for administration), it is protected by segmentation (MGMT-only) and least-privilege firewall rules.

3.3.3 Layer-2 Security Considerations (Environment Constraints)

DHCP snooping and Dynamic ARP Inspection (DAI). DHCP Snooping and Dynamic ARP Inspection are effective Layer-2 protections against rogue DHCP servers and ARP spoofing on managed switches. In this project environment, the access switching layer is implemented with GNS3 Ethernet switch nodes, which do not provide configurable enterprise Layer-2 security features comparable to IOS-managed switches. Therefore, DHCP Snooping/DAI are documented as recommended enhancements for production deployment, and the project focuses on enforceable Layer-3 segmentation and firewall-based controls within the available platform capabilities.

Overall, the applied hardening measures complement segmentation by protecting the management plane, reducing exposed services, and establishing a secure administration baseline.

Hardening Control	Status & Evidence
Strong passwords / remove default credentials	Implemented. Default administrative credentials were changed and strong passwords were applied to reduce trivial compromise risk.
Disable Telnet; SSH-only administration	Implemented. Remote shell access uses SSH (TCP/22) only; plaintext Telnet is not used. MGMT-only administrative access is enforced by MGMT rules (Figure 4).
Restrict pfSense WebGUI access (HTTPS) to MGMT	Implemented. WebGUI administration (TCP/443) is intended to be reachable only from MGMT (Figure 4). LAN attempts to reach management services are blocked by policy (Figure 6).
Minimise exposed WAN services (allow-list inbound)	Implemented. Only the DMZ web service is published to the Internet via WAN NAT (TCP/80 to DMZ_WEB=10.10.60.10) with a linked WAN rule (Figure 9). Other unsolicited inbound traffic remains blocked by default.
Block bogon/private sources on WAN (anti-spoofing baseline)	Implemented. Default WAN protections “Block private networks” and “Block bogon networks” remain enabled on the WAN interface (Figure 9a).
Disable unnecessary services	Implemented (baseline). Only required services are enabled; non-essential services are kept disabled to reduce attack surface. Where services are required, exposure is constrained by segmentation and least-privilege rules (Sections 3.1–3.2).
DHCP Snooping	Not implemented (platform constraint). DHCP Snooping is a managed-switch Layer-2 feature. The GNS3 Ethernet switch nodes used in this build do not provide configurable DHCP Snooping. Documented as a recommended enhancement for production deployments.
Dynamic ARP Inspection (DAI)	Not implemented (platform constraint). DAI requires a managed switching layer with DHCP Snooping bindings. As above, documented as a recommended enhancement given the lab platform limitations.

Table 3: Additional Security Hardening Checklist: baseline controls applied and implementation evidence.

4 Security Testing and Validation

4.1 Testing Environment

Security validation was conducted in a virtualised lab. The host platform is a Windows 11 laptop running a GNS3 VM for network emulation and a Kali Linux VM for external-style security testing. Internal endpoints were emulated using VPCS nodes (e.g., Guest1, PC-SALES, SRV-WEB, SRV-ADM). All inter-zone traffic traverses the pfSense stateful firewall, enabling policy

verification via reachability tests (ICMP) and port exposure checks (Nmap).

4.2 Validation Methodology

Two complementary methods were used:

- **Reachability testing (ICMP):** verify allowed/denied inter-zone paths match the segmentation policy (e.g., Guest isolation, LAN→MGMT deny, DMZ containment).
- **Exposure testing (Nmap):** verify the WAN attack surface is restricted to intended public services only (DMZ web publishing) [10].

4.3 Test Cases and Results

Table 4 summarises the executed tests. pfSense is stateful; therefore, results describe *initiated* traffic from the source zone.

ID	Source	Destination / Probe	Expected	Evidence
T1	Kali (WAN-side)	Nmap SYN scan to WAN IP ports 22/53/80/443	Only TCP/80 reachable	Fig. 11
T2	Guest1 (GUEST)	Ping 1.1.1.1 (Internet)	Allow	Fig. 12
T3	Guest1 (GUEST)	Ping internal gateways (e.g., 10.10.10.1, 10.10.50.1)	Deny (timeout)	Fig. 13
T4	PC-SALES (LAN)	Ping MGMT gateway/host (MGMT reachability)	Deny (timeout)	Fig. 14
T5	SRV-ADM (MGMT)	Ping internal gateway (administration reachability)	Allow	Fig. 15
T6	SRV-WEB (DMZ)	Ping LAN host (e.g., 10.10.10.101)	Deny (timeout)	Fig. 16

Table 4: Security validation summary (initiated traffic).

T1: WAN exposure restriction. From the external tester (Kali), an Nmap SYN scan confirms that only the intended public web service is reachable on the WAN address (TCP/80), while other common management and service ports (e.g., SSH/22, DNS/53, HTTPS/443) are filtered. This supports the perimeter objective of exposing only DMZ services and denying unsolicited WAN access to internal zones (Fig. 11).

T2–T3: Guest Internet access with strict isolation. Guest1 can reach the Internet for basic usage (ping to 1.1.1.1 succeeds), but cannot reach internal networks (pings to internal gateway

addresses time out). Together, these results demonstrate the intended Guest policy: outbound access is available, while lateral movement into enterprise segments is prevented (Figs. 12–13).

T4–T5: Management plane separation. A Corporate LAN endpoint (PC-SALES) is unable to reach the MGMT network (timeout), while an MGMT endpoint (SRV-ADM) can reach internal addresses required for administration. This supports the management-plane isolation goal: only the MGMT zone is positioned for administrative reachability, and non-management user networks are blocked from MGMT (Figs. 14–15).

T6: DMZ containment against pivoting. The DMZ host (SRV-WEB) cannot reach internal LAN hosts (timeout when probing 10.10.10.101), demonstrating DMZ containment and reducing pivoting risk if a public-facing server is compromised (Fig. 16). *Note:* ICMP to the firewall itself may be permitted for troubleshooting; containment is evaluated primarily against access to internal hosts/services.

5 Critical Evaluation (Strengths & Limitations)

This section critically evaluates the implemented security design using the previously defined *testable implementation metrics* (connectivity, access-control, segmentation, attack-surface, and hardening). The objective is to assess not only whether the rules function as intended, but also the robustness and gaps of the overall posture.

Strengths

Metric-driven validation improves auditability. A key strength of the project is that the security posture can be assessed using operational, repeatable metrics. Connectivity (ICMP validation) demonstrates that the baseline routing and gateway behaviours are correct (e.g., endpoints can reach their own gateway and authorised destinations). More importantly, Segmentation/Isolation (boundary testing) provides a clear, binary outcome (success vs. 100% packet loss) for critical trust boundaries such as Guest → Internal and LAN → MGMT, which makes the security claims defensible and easy to reproduce.

Least-privilege enforcement via a stateful firewall. The design centralises inter-zone control at pfSense, forcing all cross-zone flows through stateful inspection. This directly supports the Access-Control (stateful inspection) metric: traffic is permitted only when it matches explicit policy intent (e.g., MGMT-only administration, Guest Internet-only access), while unauthorised initiated flows are dropped by default. This reduces lateral movement opportunities and makes rule reasoning simpler because the trust boundaries align with Layer-3 interfaces and subnets.

Attack-surface reduction is measurable. The inclusion of Attack-Surface Metrics (Nmap scanning) is an effective way to convert a configuration claim into evidence. From an external attacker viewpoint (Kali VM), only intended service exposure should be observable. Where scans report ports as filtered rather than open, it indicates reduced attack surface and fewer reachable services to exploit. This aligns the implementation with “minimise exposure” and provides concrete proof beyond screenshots of rule lists.

Secure management plane as a hardening outcome. The project correctly distinguishes the management plane from user traffic. Under the Hardening Metrics (service security), management access is constrained to the MGMT zone and relies on encrypted administration (SSH/HTTPS). This significantly reduces the risk of credential interception and limits the blast radius of a compromised user endpoint, since administrative interfaces are not directly reachable from general-purpose zones.

5.1 Limitations

Validation relies heavily on ICMP and may not represent application-layer reality. While Connectivity and Segmentation checks using ICMP are valuable for baseline verification, ICMP results alone do not guarantee that higher-layer services behave securely. For example, a policy may block ICMP but still allow TCP sessions, or vice versa. Therefore, ICMP should be treated as a necessary but insufficient signal; application-layer validation (HTTP response, DNS resolution, SMTP banners, etc.) is required for stronger assurance.

Service availability and endpoint realism are constrained by the lab environment. Some intended tests (e.g., verifying the DMZ web service end-to-end via HTTP) are limited by the capability of endpoints used in the topology (e.g., lightweight nodes such as VPCS) and by service configuration completeness on server nodes. This reduces the coverage of the Attack-Surface and Hardening metrics, because “port open” does not necessarily mean the service is correctly configured or secure.

Policy exceptions and implicit behaviours can create interpretation ambiguity. pfSense is stateful and can include interface-specific safeguards (e.g., anti-lockout behaviours). In addition, linked NAT rules and automatic state creation can make it harder to interpret whether a behaviour is caused by a deliberate policy or an implicit mechanism. As a result, some outcomes require careful explanation (e.g., which flows are initiated vs. return traffic), and the segmentation matrix must explicitly state this assumption to avoid over-claiming isolation.

Limited depth in adversarial testing. The current validation focuses on reachability and port visibility. It does not fully emulate advanced attacker behaviours such as credential harvesting, pivoting through allowed services, exploitation attempts, or DNS tunnelling. Hence, while the

design demonstrates correct preventive controls at the network boundary, it provides weaker evidence for resilience against sophisticated threats without deeper adversarial scenarios.

Scope limitations: monitoring and detection are minimal. The project primarily demonstrates preventive controls (firewall rules and NAT). Centralised logging, alerting, IDS/IPS, and continuous monitoring are not comprehensively evaluated. Consequently, the solution is stronger at blocking unauthorised traffic than at detecting compromise or supporting incident response.

5.2 Summary

On the whole, the implementation gives a defensible baseline. Zone-based segmentation and least-privilege policies are enforced throughout, and the core assertions are backed up by reproducible tests (ICMP reachability and external port exposure with Nmap). However, the assessment is still predominantly focused on the network layer. Application-layer behavior is only lightly exercised, endpoints and services are simplified compared to a production environment, and adversarial scenarios are limited to reachability and scanning, rather than exploitation or persistence.

6 Conclusion

In this project, a robust enterprise network for TechCorp was designed and built with the use of GNS3 and pfSense stateful firewall. The use of segmentation (i.e., replacing a flat network with a zone-based architecture) reduces the network attack surface and also constrains the potential for lateral movement among internal systems.

The deployment reached a few major milestones in security. First a hierarchical Core–Distribution–Access topology was implemented to provide a scalable base, and, redundant at the physical and logical level, was supported. Second, there are now five security zones (External/WAN, Corporate, DMZ, Guest, MGMT) established to segregate sensitive assets such as management services and corporate databases from facing the public as well as untrusted guest devices. This default-deny rule is represented in the firewall policy matrix for inter-zone traffic. Third, the management plane was hardened by restricting administrator access to the MGMT subnet via HTTPS and SSH only. The equipment has had default credentials removed, and insecure protocols like Telnet have been disabled. These precautions prevent network devices from being enumerated and exploited by internal or external threat actors.

The implementation was validated by extensive test. The nmap perimeter scans and icmp reachability (from multiple zones) demonstrated that the firewall rules are truly enforcing the desired policy. The result is that they can confirm that allowed Internet access and DMZ services are

still accessible and that traffic crossing trust boundaries (Guest to Corporate, WAN to MGMT, and the like) is being blocked. Although the current setup gives a good level of security, additional work might integrate an IDPS, and centralized logging via a SIEM for enhanced visibility and threat detection [7, 8]. In summary, the OPSF development demonstrated that a stateful firewall combined with properly designed network segmentation can yield a robust, manageable infrastructure for defending corporate assets from contemporary cyber threats.

References

- [1] R. Moskowitz, D. Karrenberg, Y. Rekhter, E. Lear, and G. J. de Groot, “Address allocation for private internets.” RFC 1918 (BCP 5), Feb. 1996. Accessed: 2025-12-22.
- [2] J. Postel, “Internet control message protocol,” Tech. Rep. 792, IETF, 1981.
- [3] Netgate, “Firewall rule methodology.” <https://docs.netgate.com/pfsense/en/latest/firewall/rule-methodology.html>, 2025. Accessed: 2025-12-22.
- [4] K. Scarfone and M. Hoffman, “Guidelines on firewalls and firewall policy,” Tech. Rep. 800-41, NIST, 2009.
- [5] NIST CSRC, “least privilege (glossary).” https://csrc.nist.gov/glossary/term/least_privilege, 2025. Accessed: 2025-12-22.
- [6] Cisco Systems, “Campus lan and wireless lan solution design guide.” <https://www.cisco.com/c/en/us/td/docs/solutions/CVD/Campus/cisco-campus-lan-wlan-design-guide.html>. Accessed: 2025-12-22.
- [7] E. Gilman and D. Barth, *Zero Trust Networks: Building Secure Systems in Untrusted Networks*. O’Reilly Media, 2017.
- [8] S. Rose *et al.*, “Zero trust architecture,” Tech. Rep. 800-207, NIST, 2020.
- [9] GNS3, “Getting started with gns3.” <https://docs.gns3.com/docs/>. Accessed: 2025-12-22.
- [10] G. Lyon, “Nmap reference guide.” <https://nmap.org/book/man.html>, 2025. Accessed: 2025-12-22.
- [11] MITRE ATTCK, “Lateral movement.” <https://attack.mitre.org/tactics/TA0008/>, 2024. Accessed: 2025-12-22.
- [12] J. Stewart, *Network Security, Firewalls, and VPNs*. Jones Bartlett Learning, 2020.

A Appendix A: Screenshots and Config Snippets

System / User Password Manager

Users Groups Settings Change Password Authentication Servers

Change Password

This page changes the password for the current user in the local configuration. This affects all services which utilize the Local Authentication database (User Manager).

This page cannot change passwords for users from other authentication sources such as LDAP or RADIUS.

Database Local Authentication

Username admin

Password

Enter a new password.

Hints:
Current NIST guidelines prioritize password length over complexity.
The password cannot be identical to the username.

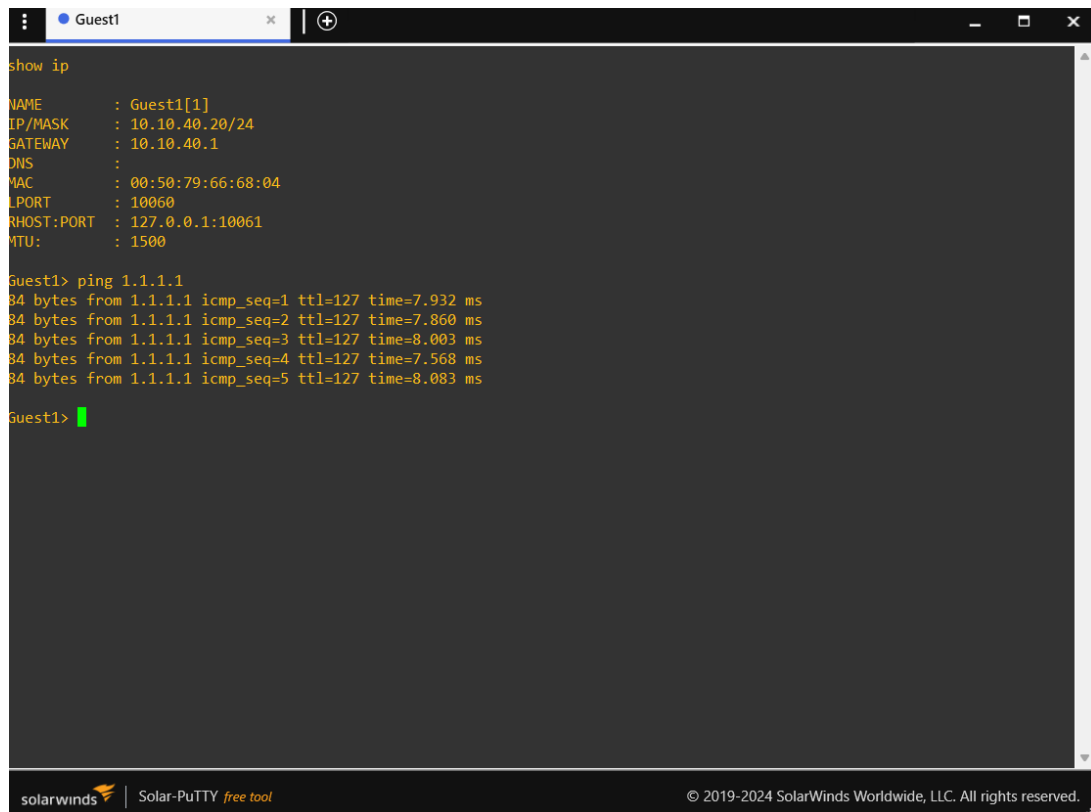
Confirmation

Type the new password again for confirmation.

Figure 10: User Password Manager.



Figure 11: T1: WAN exposure validation via Nmap (only TCP/80 reachable).



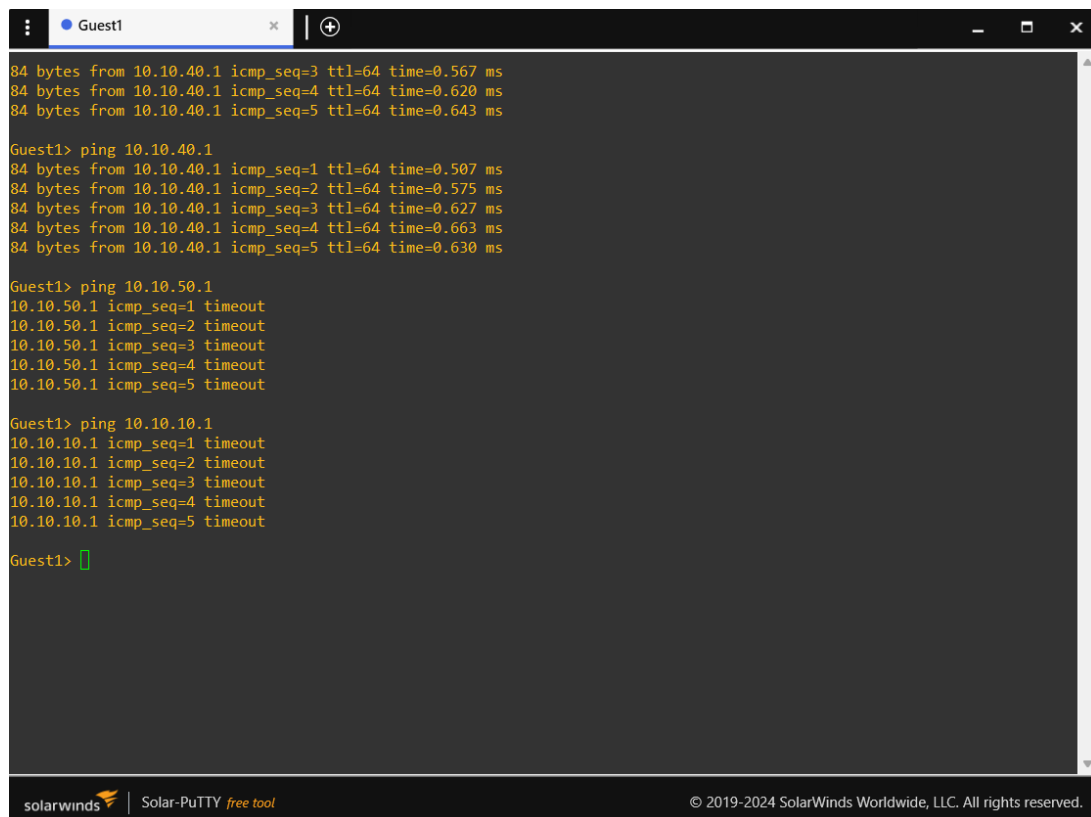
```
Guest1
show ip
NAME       : Guest1[1]
IP/MASK    : 10.10.40.20/24
GATEWAY    : 10.10.40.1
DNS        :
MAC        : 00:50:79:66:68:04
I.P.ORT    : 10060
RHOST:PORT : 127.0.0.1:10061
MTU:       : 1500

Guest1> ping 1.1.1.1
64 bytes from 1.1.1.1 icmp_seq=1 ttl=127 time=7.932 ms
64 bytes from 1.1.1.1 icmp_seq=2 ttl=127 time=7.860 ms
64 bytes from 1.1.1.1 icmp_seq=3 ttl=127 time=8.003 ms
64 bytes from 1.1.1.1 icmp_seq=4 ttl=127 time=7.568 ms
64 bytes from 1.1.1.1 icmp_seq=5 ttl=127 time=8.083 ms

Guest1>
```

solarwinds | Solar-PuTTY free tool © 2019-2024 SolarWinds Worldwide, LLC. All rights reserved.

Figure 12: T2: Guest Internet reachability (Guest1 → 1.1.1.1 succeeds).



```
64 bytes from 10.10.40.1 icmp_seq=3 ttl=64 time=0.567 ms
64 bytes from 10.10.40.1 icmp_seq=4 ttl=64 time=0.620 ms
64 bytes from 10.10.40.1 icmp_seq=5 ttl=64 time=0.643 ms

Guest1> ping 10.10.40.1
64 bytes from 10.10.40.1 icmp_seq=1 ttl=64 time=0.507 ms
64 bytes from 10.10.40.1 icmp_seq=2 ttl=64 time=0.575 ms
64 bytes from 10.10.40.1 icmp_seq=3 ttl=64 time=0.627 ms
64 bytes from 10.10.40.1 icmp_seq=4 ttl=64 time=0.663 ms
64 bytes from 10.10.40.1 icmp_seq=5 ttl=64 time=0.630 ms

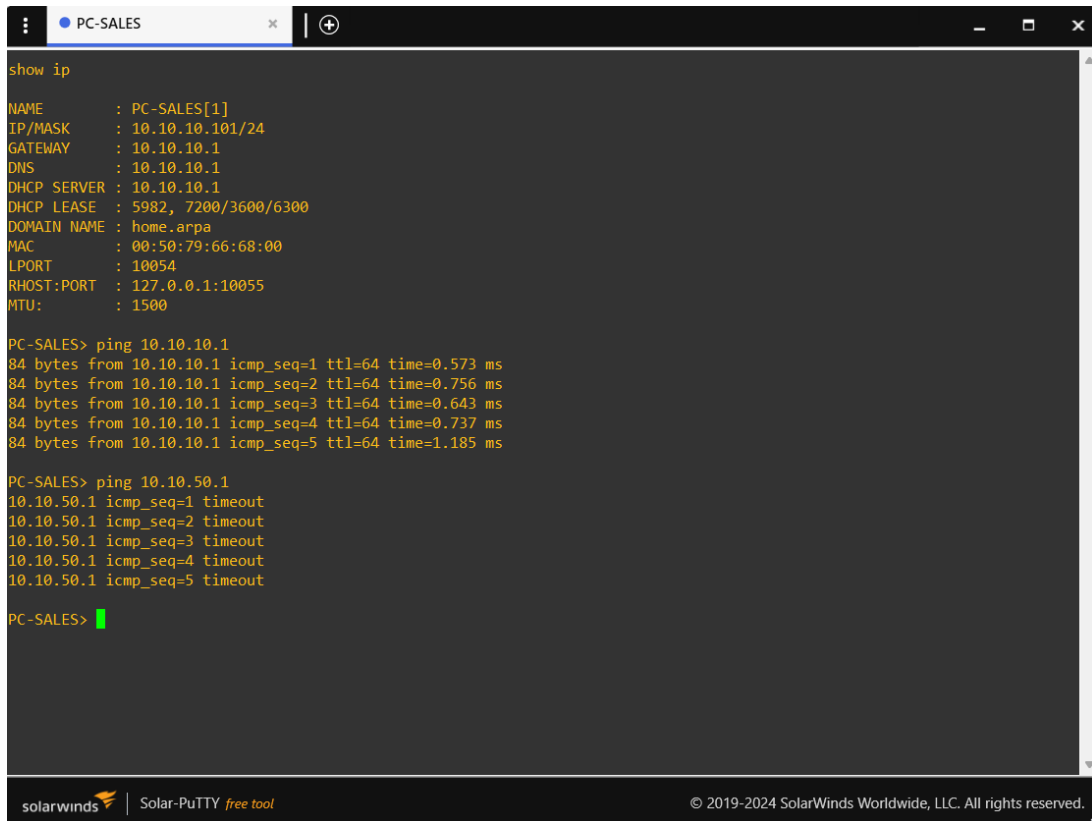
Guest1> ping 10.10.50.1
10.10.50.1 icmp_seq=1 timeout
10.10.50.1 icmp_seq=2 timeout
10.10.50.1 icmp_seq=3 timeout
10.10.50.1 icmp_seq=4 timeout
10.10.50.1 icmp_seq=5 timeout

Guest1> ping 10.10.10.1
10.10.10.1 icmp_seq=1 timeout
10.10.10.1 icmp_seq=2 timeout
10.10.10.1 icmp_seq=3 timeout
10.10.10.1 icmp_seq=4 timeout
10.10.10.1 icmp_seq=5 timeout

Guest1>
```

solarwinds | Solar-PuTTY free tool © 2019-2024 SolarWinds Worldwide, LLC. All rights reserved.

Figure 13: T3: Guest isolation (Guest1 → internal addresses blocked).



```
PC-SALES

show ip

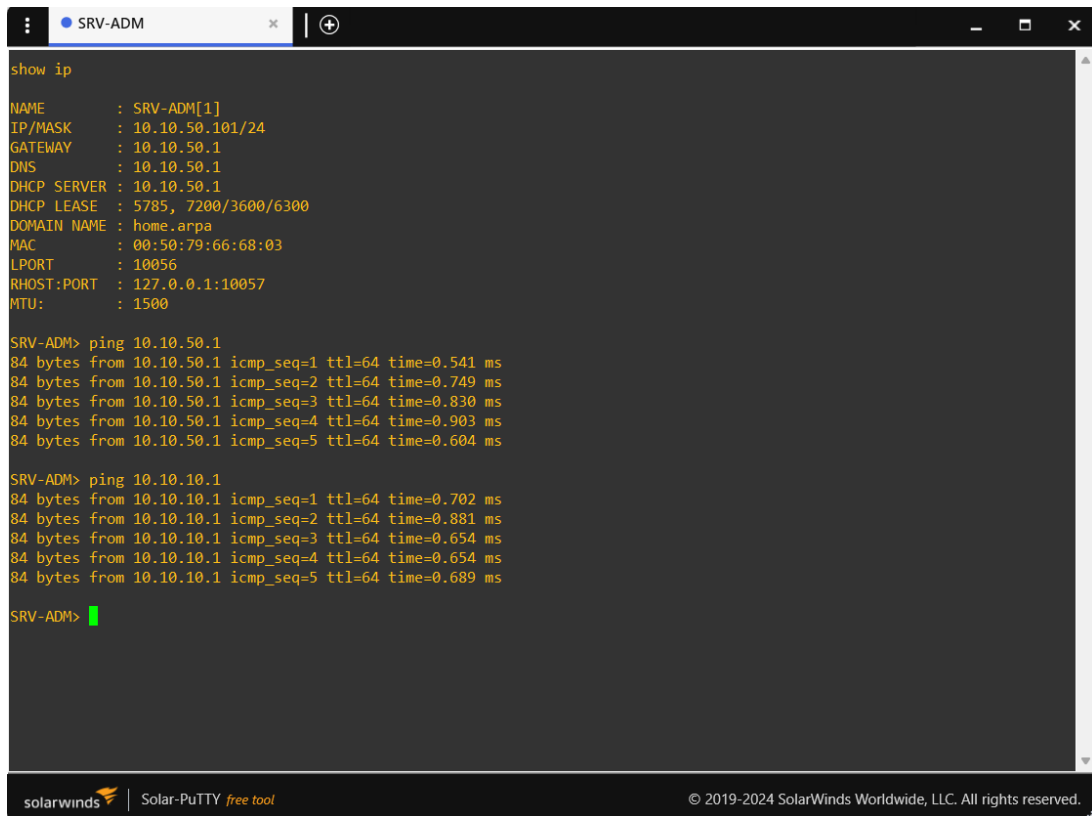
NAME       : PC-SALES[1]
IP/MASK    : 10.10.10.101/24
GATEWAY    : 10.10.10.1
DNS        : 10.10.10.1
DHCP SERVER: 10.10.10.1
DHCP LEASE : 5982, 7200/3600/6300
DOMAIN NAME: home.arpa
MAC        : 00:50:79:66:68:00
LPORT     : 10054
RHOST:PORT : 127.0.0.1:10055
MTU       : 1500

PC-SALES> ping 10.10.10.1
84 bytes from 10.10.10.1 icmp_seq=1 ttl=64 time=0.573 ms
84 bytes from 10.10.10.1 icmp_seq=2 ttl=64 time=0.756 ms
84 bytes from 10.10.10.1 icmp_seq=3 ttl=64 time=0.643 ms
84 bytes from 10.10.10.1 icmp_seq=4 ttl=64 time=0.737 ms
84 bytes from 10.10.10.1 icmp_seq=5 ttl=64 time=1.185 ms

PC-SALES> ping 10.10.50.1
10.10.50.1 icmp_seq=1 timeout
10.10.50.1 icmp_seq=2 timeout
10.10.50.1 icmp_seq=3 timeout
10.10.50.1 icmp_seq=4 timeout
10.10.50.1 icmp_seq=5 timeout

PC-SALES>
```

Figure 14: T4: LAN to MGMT blocked (PC-SALES → MGMT timeout).



```
SRV-ADM

show ip

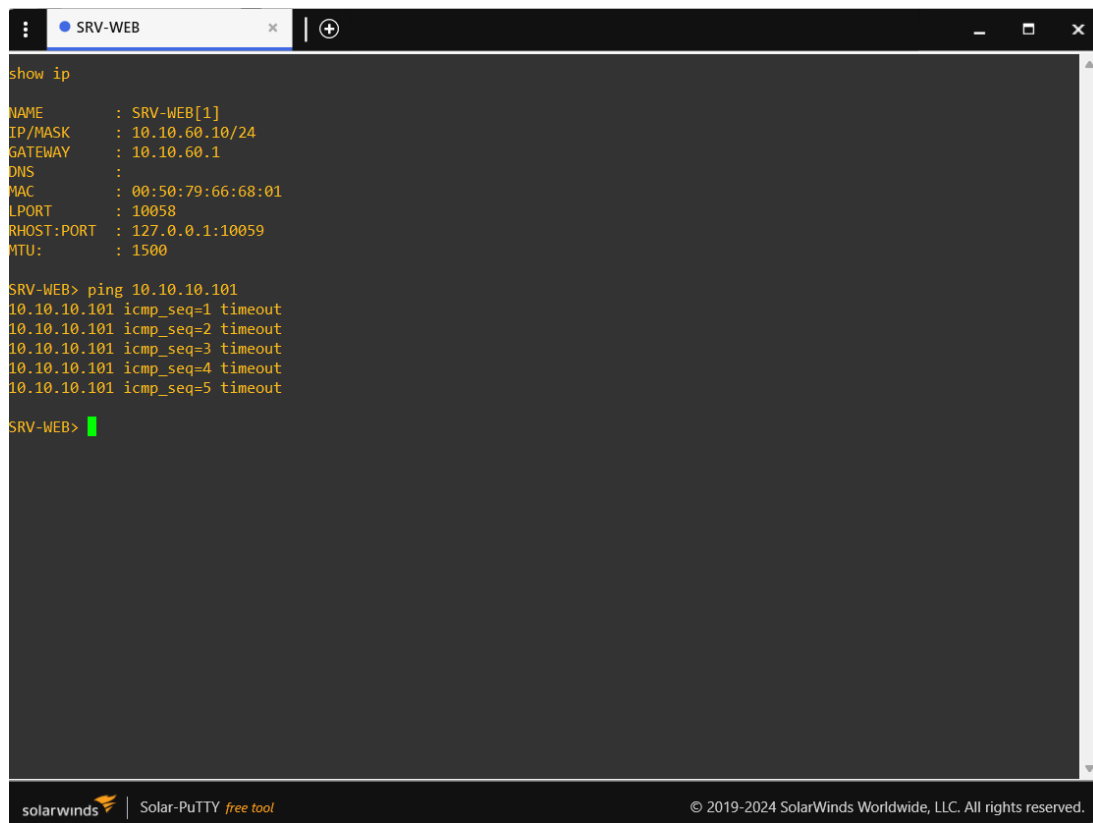
NAME       : SRV-ADM[1]
IP/MASK    : 10.10.50.101/24
GATEWAY    : 10.10.50.1
DNS        : 10.10.50.1
DHCP SERVER: 10.10.50.1
DHCP LEASE : 5785, 7200/3600/6300
DOMAIN NAME: home.arpa
MAC        : 00:50:79:66:68:03
LPORT     : 10056
RHOST:PORT : 127.0.0.1:10057
MTU       : 1500

SRV-ADM> ping 10.10.50.1
84 bytes from 10.10.50.1 icmp_seq=1 ttl=64 time=0.541 ms
84 bytes from 10.10.50.1 icmp_seq=2 ttl=64 time=0.749 ms
84 bytes from 10.10.50.1 icmp_seq=3 ttl=64 time=0.830 ms
84 bytes from 10.10.50.1 icmp_seq=4 ttl=64 time=0.903 ms
84 bytes from 10.10.50.1 icmp_seq=5 ttl=64 time=0.604 ms

SRV-ADM> ping 10.10.10.1
84 bytes from 10.10.10.1 icmp_seq=1 ttl=64 time=0.702 ms
84 bytes from 10.10.10.1 icmp_seq=2 ttl=64 time=0.881 ms
84 bytes from 10.10.10.1 icmp_seq=3 ttl=64 time=0.654 ms
84 bytes from 10.10.10.1 icmp_seq=4 ttl=64 time=0.654 ms
84 bytes from 10.10.10.1 icmp_seq=5 ttl=64 time=0.689 ms

SRV-ADM>
```

Figure 15: T5: MGMT reachability to internal network (SRV-ADM can reach internal gateway).



```
SRV-WEB
show ip
NAME       : SRV-WEB[1]
IP/MASK    : 10.10.60.10/24
GATEWAY    : 10.10.60.1
DNS        :
MAC        : 00:50:79:66:68:01
LPORT      : 10058
RHOST:PORT : 127.0.0.1:10059
MTU        : 1500

SRV-WEB> ping 10.10.10.101
10.10.10.101 icmp_seq=1 timeout
10.10.10.101 icmp_seq=2 timeout
10.10.10.101 icmp_seq=3 timeout
10.10.10.101 icmp_seq=4 timeout
10.10.10.101 icmp_seq=5 timeout

SRV-WEB>
```

The screenshot shows a terminal window titled 'SRV-WEB' with a dark background and yellow text. The user has entered the command 'show ip', which displays network configuration details for 'SRV-WEB[1]'. Below this, the user has entered a series of five 'ping' commands to the IP address 10.10.10.101, all of which result in 'timeout' responses. The terminal window includes standard window controls at the top and a footer with the SolarWinds logo and copyright information.

Figure 16: T6: DMZ containment (SRV-WEB → LAN host blocked).